

Comprehensive SOC Lab Deployment & RedLine Stealer Threat Analysis

Air-Gapped Malware Detonation, Static/Dynamic Reverse Engineering,
and SIEM Detection

University / Professional SOC Engineering Defense

VirtualBox Lab

RedLine Stealer

Elastic SIEM

YARA Rules

Project Architecture & Network Isolation

HYPERVISOR

Oracle VirtualBox

Host-based virtualization platform for isolated lab deployment

NETWORK CONFIGURATION

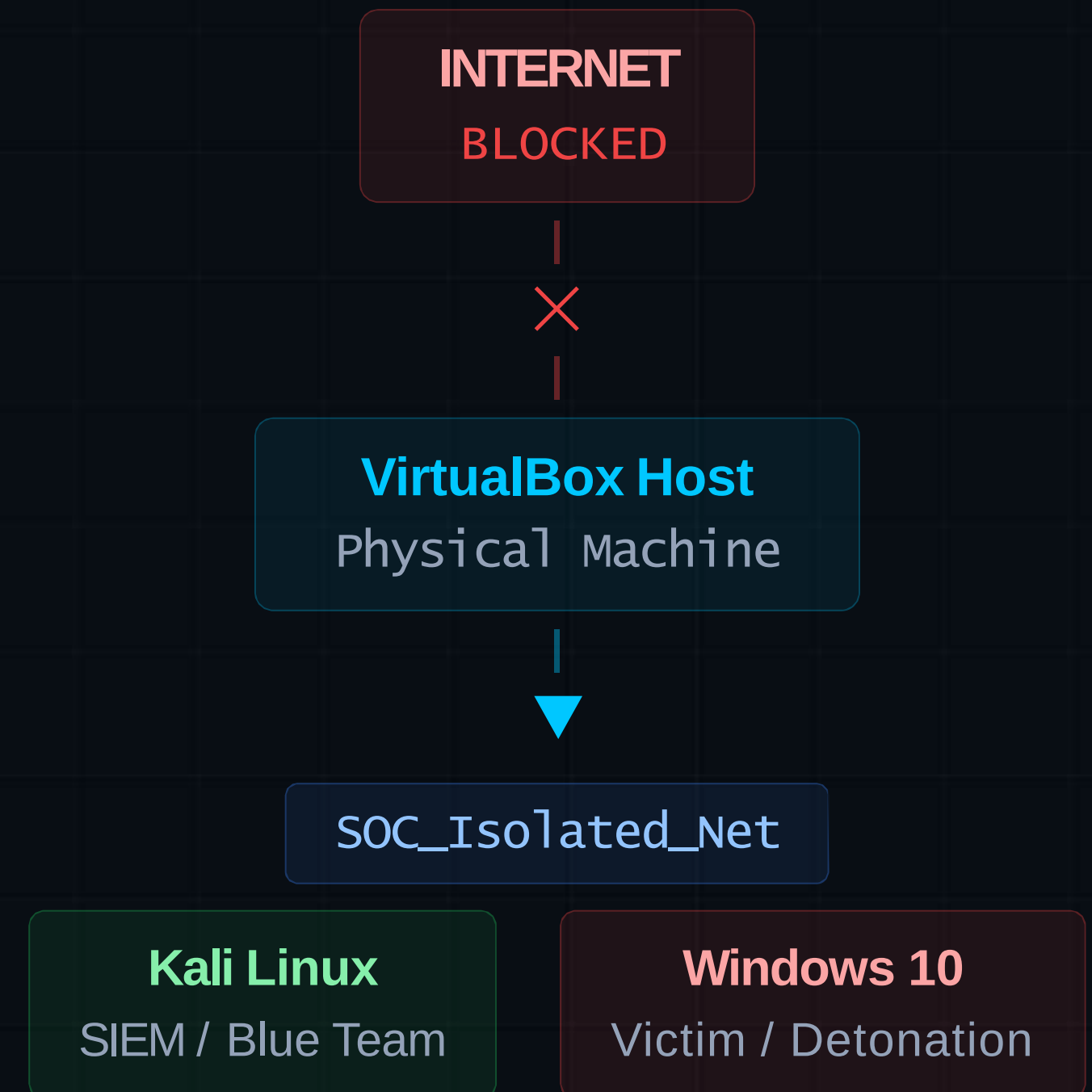
Internal Network Mode

Name: `SOC_Isolated_Net`

No NAT—zero external internet access from VMs

OPSEC RATIONALE

Strict containment ensures malware cannot reach external C2 infrastructure or infect the physical host during detonation.



The Blue Team Hub — Kali Linux Setup

OS: Kali Linux

RAM: 8 GB

vCPUs: 2

Docker: Containerized SIEM

SIEM STACK — ELASTIC

Elasticsearch

- Log ingestion, indexing, and search engine

Kibana

- SIEM dashboard and threat hunting UI

Fleet Server

- Agent enrollment and policy management

STATIC ANALYSIS TOOLS

CAPA

- Capability mapping to MITRE ATT&CK framework

FLOSS

- Obfuscated string extraction and deobfuscation

DYNAMIC ANALYSIS TOOLS

Wireshark

- Full packet capture and protocol analysis

YARA

- Pattern-based malware signature rules

The Detonation Zone — Windows 10 Setup

VICTIM VM SPECS

Windows 10 — 4 GB RAM

Windows Defender: **DISABLED**

Windows Firewall: **DISABLED**

TELEMETRY COLLECTION

Elastic Agent — Enrolled to Fleet Server

Forwards Sysmon event logs to Kali Linux

SIEM in real-time

PRE-DETONATION SNAPSHOT

Clean_State_Ready_For_Detonation

VirtualBox snapshot taken before malware execution for clean-state rollback

TOOL STAGING — C:\Tools

Detect It Easy (DIE)

Static architecture analysis — PE headers, packer/compiler identification

Sysinternals Suite

Process Monitor (Procmon) — filesystem, registry, and network event capture

Process Explorer — live process tree and parent-child relationships

TCPView — real-time TCP/UDP connection monitoring

Regshot

Registry diffing — pre/post detonation snapshot comparison

MITRE ATT&CK Mapping

PERSISTENCE

Scheduled Task

Creates recurring tasks to survive reboots and maintain foothold

DEFENSE EVASION

Masquerading

Process Injection

Deobfuscate/Decode

AES in-memory decryption to evade static scanners

CREDENTIAL ACCESS

OS Credential Dumping

Browser DB
SQLite queries, bcrypt.dll AES-GCM decryption of saved passwords

DISCOVERY

Query Registry

System Info

Discovery

Security

Software

Discovery

WMI queries
enumerate CPU, AV, and installed programs

COMMAND & CONTROL

Application Layer Protocol

WCF/SOAP over HTTP—evades standard web proxies and firewalls

RedLine Execution & Masquerading

INITIAL VECTOR — SOCIAL ENGINEERING

NetFlix Checker by xRisky v2.exe

Dropper disguised as a legitimate Netflix credential-checking tool

IN-MEMORY DECRYPTION

AES-CBC — PKCS7 Padding

Hardcoded Key + IV decrypts core payload entirely in memory — evades on-disk scanners

DROPPER STAGING PATH

%AppData%\

Writes payload to AppData — no Admin privileges required, bypasses UAC

MASQUERADING — FAKE SYSTEM PROCESSES

winlogon.exe

Legitimate path: C:\Windows\System32

Malicious path: %AppData%\winlogon.exe

svchost.exe

Legitimate path: C:\Windows\System32

Masqueraded outside System32 — immediate IoC

chrome.exe

Impersonates browser process to blend in with network traffic

C2 Communication —WCF & SOAP

PROTOCOL

Windows Communication Foundation (WCF)

SOAP XML requests over HTTP—evades standard web proxy filters and firewall rules targeting raw TCP/HTTP

BINDING

BasicHttpBinding

Uses XML Dictionary Reader Quotas to negotiate session parameters with the C2 server

OBSERVED C2 PORT

17044

Captured via TCPView during dynamic analysis —
non-standard port to avoid signature detection

WCF ENDPOINTS USED

Step 1—Initiate Session

IRemoteEndpoint/Connect

Step 2 — Download Task Config

IRemoteEndpoint/GetConfiguration

Step 3 — Exfiltrate Stolen Data

IRemoteEndpoint/SendLogs

Configuration pulled dynamically from C2 —
attacker can retask the malware remotely
without recompiling

Browser Credential Harvesting & API Abuse

STAGING DIRECTORY

%LocalAppData%\Yandex\YaAddon

Payload staged in non-suspicious Yandex browser addon path

WINDOWS CNG API ABUSE (bcrypt.dll)

BCryptOpenAlgorithmProvider (AES-GCM)

BCryptDecrypt

Forces Windows' own cryptography APIs to decrypt browser-stored passwords into plaintext

BROWSER SQLite CREDENTIAL QUERY

```
SELECT origin_url, username_value,  
password_value FROM logins;
```

Executed against Chromium-based browser login databases —captures encrypted passwords for decryption via bcrypt.dll

TARGETED BROWSERS

Chrome, Edge, Brave, Opera, Yandex —any Chromium-based browser storing credentials in local SQLite Login Data files

Crypto Wallet & Session Harvesting

CHROMIUM EXTENSION WALLETS

MetaMask

nkbihfbeogaeaoeh1efnkodbefgpgknn

Binance Chain Wallet

fhbohmbbehdbohhaemidkfggcfjhdome

Yoroi Wallet

Hunts Local Extension Settings
directory by extension ID

DESKTOP WALLET FILES

Electrum

Wallet.dat and
config files copied

Exodus

Full AppData
exodus.wallet
directory
exfiltrated

Armory

Bitcoin cold
storage wallet files
targeted

SESSION HIJACKING

Telegram Desktop

%AppData%\Telegram
Desktop\tdata
Copies session files to clone
the entire account

Discord

%AppData%\discord\Local
Storage\leveldb
Regex-based token
extraction for account
takeover

Host Profiling & Exfiltration

WMI — CPU ENUMERATION

```
SELECT Name, NumberOfCores FROM  
win32_Processor
```

Profiles hardware to determine sandbox vs. real environment

WMI — ANTI VIRUS DISCOVERY

```
SELECT DisplayName FROM AntivirusProduct
```

Enumerates active security software to report to C2 and adjust behavior

MACHINE FINGERPRINT (HWID)

```
MachineID = MD5( DomainName |  
Username | DiskSerial )
```

Unique victim fingerprint sent with every data package to the C2 for tracking

DESKTOP SCREENSHOT CAPTURE

Graphics.CopyFromScreen

Captures desktop as a Base64-encoded PNG and includes it in the SendLogs exfiltration payload

Extracted Indicators of Compromise (IoCs)

FILE HASH

SHA-256

9d8b74681329a4358dbb8e1f57b322589255018617ba85a1a1f10926ed0a7b46

DROPPER

Filename / Initial Vector

Desktop\NetFlix Checker by xRisky v2.exe

C2 DOMAIN

Malicious Domain — Dynamic DNS

siyatermi.duckdns.org

C2 IP ADDRESS

192.169.69.26

Resolved from siyatermi.duckdns.org at time of detonation

C2 PORT

17044

Non-standard WCF/SOAP port — captured live via TCPView during dynamic analysis

Threat Hunting in Elastic SIEM —KQL Rules

Sysmon Event ID 1 Detecting Process Masquerading

```
process.name : ("winlogon.exe" or "svchost.exe" or "chrome.exe") and  
process.path : *AppData*
```

Triggers a **CRITICAL alert** when any core Windows binary executes from AppData—a definitive masquerading IoC

Sysmon Event ID 3 Detecting C2 Traffic —Non-Standard SOAP Port

```
destination.ip : "192.169.69.26" or destination.port : 17044
```

Flags any network connection to the **known C2 IP** or the **non-standard WCF/SOAP port**—blocks exfiltration channel

YARA Signature Detection

● ● ● RedLine.yara

```
rule RedLine_Malware_Detection { meta: author =
"DEPI Incident"           = "Detects RedLine Stealer"
description:
malware_strings: $mz = { 4D 5A } / windows PE
Header $Compilation_Name = "NetFlix Checker by
xRisky" ascii $C2_URL = "siyatermi.duckdns.org"
ascii $Created_Directory = "YaAddon" ascii wide
condition: $mz at 0 and ($Compilation_Name or
$C2_URL or $Created_Directory) }
```

RULE LOGIC

\$mz at 0—confirms Windows PE executable (MZ magic bytes)

\$C2_URL—matches hardcoded C2 domain in memory

\$Created_Directory—matches staging directory string

\$Compilation_Name—matches dropper artefact string

EXECUTION COMMAND

```
yara RedLine.yara
malware\ -s
```

Successfully detected the
masqueraded **winlogon.exe** during / 14

Prevention & Mitigation Strategy

01 Application Control

AppLocker Policy

- Deny **.exe** execution from **%AppData%**
- Deny **.dll** execution from **%LocalAppData%**
- Block execution from **Temp** directories

Primary defense against dropper execution — eliminates the initial foothold vector

02 Network Denial

Firewall + DNS Filtering

- Block IP **192.169.69.26** at perimeter firewall
- DNS filter entire ***.duckdns.org** zone
- Block non-standard port **17044** outbound

Kills the WCF C2 communication channel — prevents configuration download and data exfiltration

03 EDR Detection Rules

API Behavior Monitoring

- Alert on rapid **BCryptOpenAlgorithmProvider** calls
- **BCryptDecrypt** combined with SQLite DB reads
- Flag untrusted binaries accessing browser credential stores

Catches Windows CNG API abuse — detects credential harvesting before exfiltration occurs